BTS SIO • SPÉCIALITÉ SISR

Compte-Rendu de Travaux Pratiques

Configuration des droits, habilitations et sécurité de domaine

ÉTUDIANT
Guillian Roy

DATE DU TP
23 Septembre 2026

MACHINE / OS
SRV_AD01 (Win Server 2022)

DOMAINE ACTIVE DIRECTORY
mook.local

RESSOURCES ALLOUÉES
4 Go RAM • IP 192.168.1.10

STATUT
100% Opérationnel

1 Environnement et Configuration Initiale (Étape 1)

Pour ce TP, j'ai mis en place une machine virtuelle sous **Windows Server 2022** (nommée `SRV_AD01`) avec 4 Go de RAM.

> 💡 **Choix techniques & Difficultés résolues**
> Au niveau du réseau, le TP demandait un réseau Privé Hôte (Host-only). Initialement, j'avais configuré la carte en "LAN Segment", ce qui isolait la machine. J'ai ensuite corrigé cela pour permettre la communication avec l'hôte physique, avec l'IP statique `192.168.1.10`.



Figure 1 : Vérification de la configuration IP statique (192.168.1.10 / 255.255.255.0)

2 Installation et promotion du domaine AD DS (Étape 2)

J'ai installé le rôle Active Directory Domain Services (AD DS) et promu le serveur en tant que contrôleur de domaine principal de la forêt.

- **Nom de domaine choisi :** `mook.local`
- **Contrôleur de domaine :** `SRV_AD01`

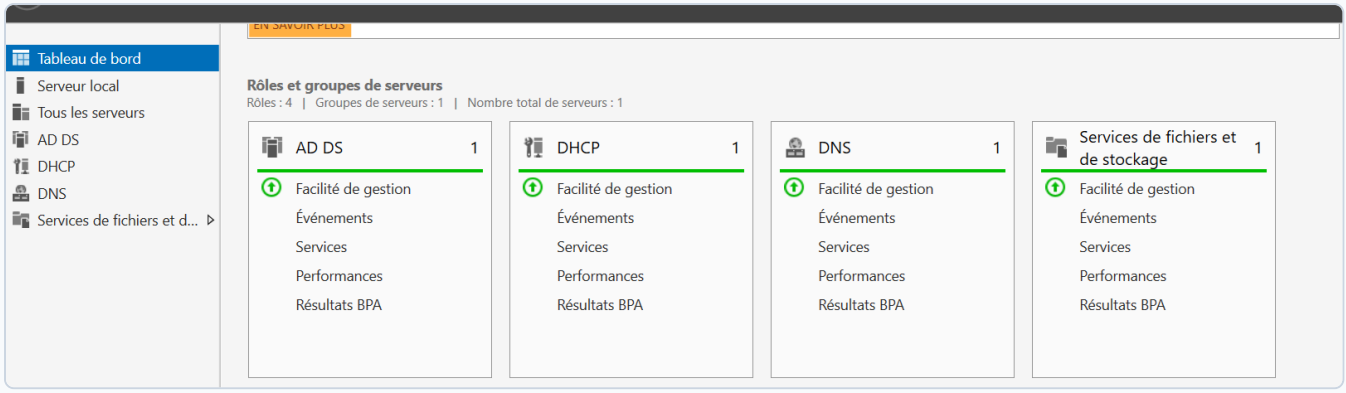


Figure 2 : Console Gestionnaire de serveur confirmant la promotion du domaine mook.local

3 Création des Unités d'Organisation et des Groupes (Étape 3)

Afin d'organiser l'annuaire selon les services de l'entreprise, j'ai structuré l'annuaire `mook.local` selon la hiérarchie suivante :

- Une Unité d'Organisation (OU) principale : `Siege`
- Deux sous-OUs dédiées : `Groupes` et `Utilisateurs`
- 5 groupes de sécurité globaux selon la nomenclature métier : `GRP_Commercial`, `GRP_Achats`, `GRP_Logistique`, `GRP_Supports` et `GRP_Administrateurs`.

> 🎯 **Justification métier**
> Cette structuration permet de cloisonner hermétiquement la gestion des utilisateurs et facilite l'application ciblée des stratégies de groupe (GPO) par service fonctionnel.

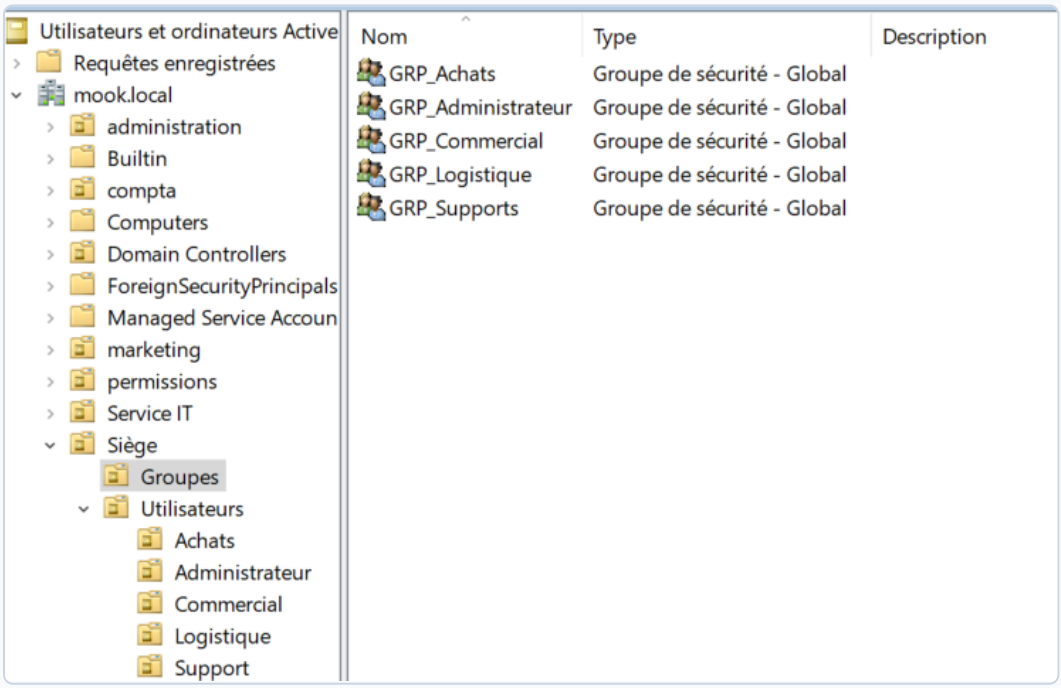


Figure 3 : Arborescence AD DS avec l'OU Siege, ses sous-OUs et les groupes de sécurité créés

4 Peuplement et Gestion du cycle de vie des utilisateurs (Étapes 4, 5 & 6)

J'ai exécuté le script PowerShell fourni pour automatiser la création des **65 comptes utilisateurs**. Les collaborateurs ont ensuite été affectés à leurs groupes de sécurité respectifs.

> 🛡️ **Désactivation des comptes obsolètes (PSSI)**
> Conformément à la politique de sécurité de l'entreprise, j'ai identifié et **désactivé 5 comptes utilisateurs inactifs** depuis plus de 90 jours via script PowerShell.
> *Justification métier :* Il est préconisé de désactiver un compte plutôt que de le supprimer immédiatement afin de conserver les identifiants de sécurité (SID) dans l'historique des permissions NTFS, et de permettre une réactivation instantanée en cas d'erreur ou de retour du salarié.

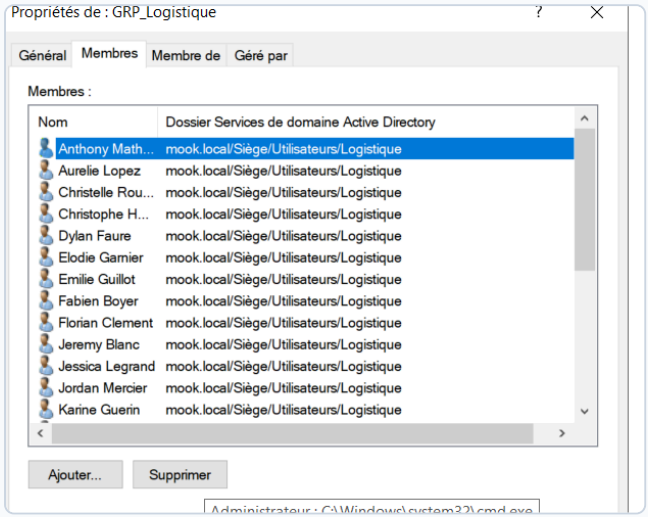


Figure 4 : Membres affectés au groupe GRP_Logistique

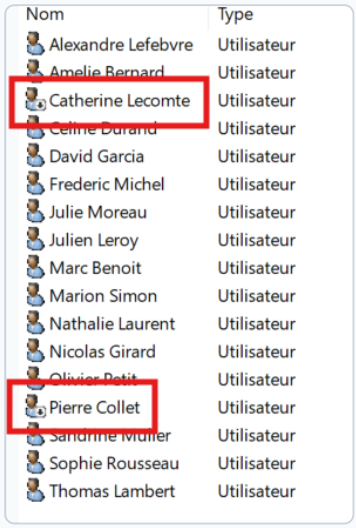


Figure 5 : Comptes obsolètes identifiés et désactivés (flèche noire)

5 Création des partages de fichiers et principe de moindre privilège (Étape 7)

J'ai créé trois espaces de stockage à la racine `C:\Partages` : `Commercial`, `Comptabilite` et `Commun`.

Pour respecter scrupuleusement le principe du moindre privilège, les partages SMB sont configurés avec "Tout le monde" en Contrôle Total au niveau du partage réseau, mais **la véritable sécurité est verrouillée par les permissions NTFS** en cassant l'héritage parent.

POWERSHELL • DURCISSEMENT NTFS (EXTRAIT) ACL RESTRICTION

```
# Exemple de règle stricte appliquée sur le dossier Comptabilité
$ruleComp = New-Object System.Security.AccessControl.FileSystemAccessRule(
    "MOOK\GRP_Supports",
    "Modify",
    "ContainerInherit,ObjectInherit",
    "None",
    "Allow"
)
$aclComp.AddAccessRule($ruleComp)
```

> 📋 **Justifications métier des droits attribués**

- **Commercial :** `GRP_Commercial` en Modification pour travailler sur leurs fichiers. Aucun accès pour les autres services.
- **Comptabilité :** `GRP_Supports` en Modification. `GRP_Administrateurs` en Lecture seule (rôle de contrôle).
- **Commun :** `Utilisateurs du domaine` en Lecture seule. Seul `GRP_Administrateurs` dispose de l'écriture pour diffuser des documents officiels.

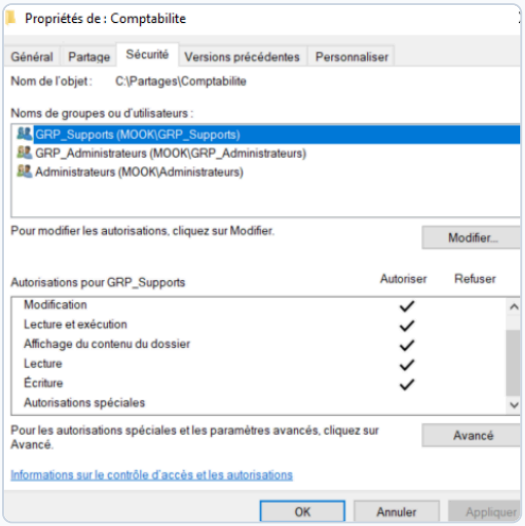


Figure 6 : Droits NTFS stricts sur Comptabilite (GRP_Supports en Modification)

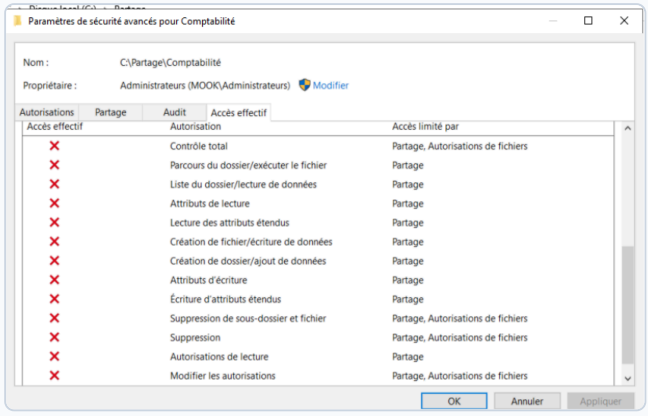


Figure 7 : Preuve par Accès effectif : refus total pour les utilisateurs non autorisés

6 Stratégie de mots de passe robustes (Étape 8)

J'ai configuré et durci la `Default Domain Policy` via PowerShell pour respecter les normes strictes de la PSSI de SecuriTech :

- **Longueur minimale :** 12 caractères
- **Complexité des mots de passe :** Activée (majuscules, minuscules, chiffres, caractères spéciaux)
- **Durée de vie maximale :** 90 jours
- **Historique mémorisé :** 5 derniers mots de passe

POWERSHELL • DEFAULT DOMAIN PASSWORD POLICY — GPO

```
Set-ADDefaultDomainPasswordPolicy -MinPasswordLength 12 -ComplexityEnabled $true `
    -MaxPasswordAge (New-TimeSpan -Days 90) -PasswordHistoryCount 5
gpupdate /force
```

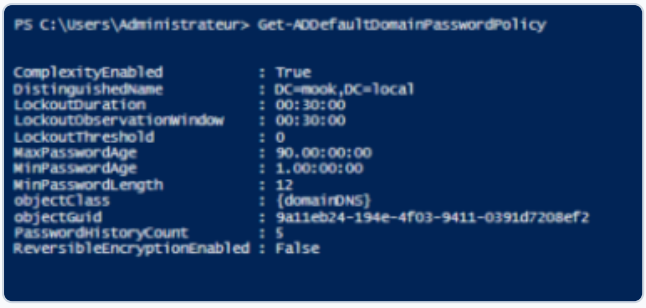


Figure 8 : Paramètres validés via Get-ADDefaultDomainPasswordPolicy



Figure 9 : Rejet immédiat (erreur 2245) lors d'un mot de passe non conforme

7 Difficultés rencontrées et Auto-évaluation (Étape 14)

⚠️ Difficultés techniques rencontrées & Solutions apportées

1. **Chemins LDAP du script :** Le script de création des utilisateurs (Étape 4) ciblait en dur le domaine `securitech.local`, alors que mon domaine était `mook.local`. J'ai adapté les chemins LDAP pour pointer vers le bon domaine sans bloquer le déroulement du TP.
2. **Attribution NTFS & Ordre de création :** L'application des droits NTFS par script a échoué initialement car le groupe `GRP_Administrateurs` n'existait pas encore lors de l'exécution, provoquant une erreur de SID introuvable. J'ai résolu le blocage en créant le groupe au préalable et en exploitant des SID reconnus universellement.

✅ Auto-évaluation globale

Toutes les configurations et exigences demandées sont **pleinement opérationnelles**. Le principe du moindre privilège a été respecté de bout en bout, la sécurité du domaine a été durcie (mots de passe, cycle de vie des comptes inactifs, segmentation des partages NTFS) et les lacunes initiales de l'entreprise ont été comblées. J'estime avoir atteint l'intégralité des objectifs du TP SISR.